TREPATH 2.6 AUTONOMOUS ATTACK-PATH VALIDATION, TA

Authorized Assessment Scope (127.0.0.1) | TrePath 2.6 Autonomous Attack-Path Validation, Target Intelligence & RTEX Assurance Eng

Client / Scope	Expedite Consults Security Lab (Written Lab Owner ROE) - OWASP Juice Shop Controlled Lab E2E (TrePath 2.4) (127.0.0.1)
Scan Execution & Signing Window	Scan Completed: 2026-11-02 17:58:03 UTC | Report Rendered & Signed: 2026-11-02 17:58:04 UTC (0s UTC Drift | Scan #43 | Profile: controlled_lab_active_validation)
Assessment Engine & Build	TrePath 2.6 Autonomous Attack-Path Validation, Target Intelligence & RTEX Assurance Engine (Build: TP26-BUILD-20261102-AUTONOMOUS-ASSURANCE | Commit: c82e71a904d3)
Document Classification	CONFIDENTIAL - Executive, Technical & Cryptographic Deliverable
T0 Baseline Calibrated Risk	HIGH (7.5 / 10 | 75.3 / 100 Calibrated Index: Confirmed Compromise=53.0 pts, Control Gaps=0.7 pts, Surface/Baseline=21.6 pts)
T1 Post-Retest Verified Risk	1.2 / 10 (5 Executed Retests Recorded in RTEX Ledger | Verified Risk Reduction: 6.3 / 10)
Hypothetical SLA Forecast	VERIFIED_POST_RETEST_CLOSURE (5 Retests Verified in RTEX): Target 2.1 / 10 (LOW) upon full RTEX closure
Verified Compromise / Admin Auth Status	1 CONFIRMED_ADMIN_AUTH (JS-AUTH-BYPASS-001) + 2 IMPACT_VERIFIED Safe PoC(s) (JS-SQLI-SEARCH-001, JS-BAC-ADMIN-USERS-001)
7-Stage Scope Reconciliation Funnel	5 Requested Target(s) -> 5 ROE Authorized -> 1 Resolved Host(s) -> 1 In-Scope Origin Asset(s) -> 0 Out-of-Scope Probed -> 22 HTTP Endpoints
Port & Transport Discovery State	Raw TCP Port Scan: 1 open ports (EXECUTED_WITH_OPEN_PORTS) | Application Transport: 22 HTTP(S) endpoints reachable across 1 origin(s)
Finding Reconciliation (6-Tier)	5 Raw Observations -> 5 Consolidated Security Findings + 0 Recon/Surface Items + 0 Sensor Health Event
Calibrated Threat Intelligence (KEV)	0 Raw KEV Matches -> 0 Unique KEV CVEs | 0 CVE_APPLICABILITY_CONFIRMED | 0 CVE_CORRELATED (Banner Only)
4-Metric Sensor Coverage & Gate	**Gate: PASSED_WITH_EXPLICIT_EXCLUSIONS | Installed: 100.0% (6/6) | Operational: 100.0% (6/6) | Execution: 100.0% (6/6) | Applicable: 100.0% (6/6)**
EvidenceCore Ed25519 & Consistency	Consistency: 100.0% (5/5 Invariants) | Ed25519 Signature: VERIFIED_AUTHENTIC (Manifest SHA-256: f21ce37d4ae6acd21f7bb5c4...)
Platform-Aware Remediation	Multi-Origin Web & API Hardening Enforced across 1 In-Scope Asset(s) (HTTP Security Headers, TLS & Endpoint Access Controls)
Pre-Render Quality Gate	**PASSED (26/26 Acceptance Rules + AT-01..AT-10 + NG-01..NG-06 + Ed25519 Tamper Self-Test PASSED | Score=75.3/100 (7.5/10))**

Prepared by Expedite Consults Ltd | Generated 2026-11-02 17:58:04 UTC | TREPATH 2.6 AUTONOMOUS ATTACK-PATH VALIDATIO

1. Executive Summary & Proof-Driven Assessment Overview

This assessment was executed by TrePath 2.6 Autonomous Attack-Path Validation, Target Intelligence & RTEX Assurance Engine against 5 submitted target(s) reconciled to 1 authorized in-scope origin asset(s) (127.0.0.1) under the 'controlled_lab_active_validation' Rules of Engagement. TrePath 2.6 Autonomous Attack-Path Validation, Target Intelligence & RTEX Assurance Engine enforces immutable 9-field asset provenance, per-origin written authorization governance, effective HTTP header-policy evaluation, 4-track score separation, pre-execution sensor readiness gating, 5-stage attack-path progression, and verifiable RFC 8032 Ed25519 cryptographic signing.

1.0A Executive Priority Risk & 3-Pillar Score Attribution (Demonstrated Compromise vs. Control Hygiene)

Posture Panel	State Type	Risk Score	Key Drivers & Proof Scope
PANEL-1-MEASURED-BASELINE	MEASURED_AT_T0	**7.5 / 10 (HIGH)**	5 Consolidated Findings across 1 origin(s): Confirmed Compromise=53.0 pts | Control Gaps=0.7 pts | Surface/Baseline=21.6 pts.
PANEL-2-MEASURED-POST-RETEST	MEASURED_AT_T1	1.2 / 10 (5 Retests)	RTEX Ledger active (5 retests executed; Verified T1 Risk Reduction: 6.3 / 10).
PANEL-3-HYPOTHETICAL-FORECAST	HYPOTHETICAL_PROJECTION	2.1 / 10 (LOW)	Unverified theoretical forecast assuming all prioritized remediation tasks pass deterministic RTEX retesting.

1.0B Four-Metric Sensor Coverage Model (Installed vs. Operational vs. Execution vs. Applicable)

Sensor Coverage Metric	Measured Coverage	Operational & Evidentiary Definition
1. Installed Coverage	100.0% (6/6)	Sensors installed and registered in TrePath 2.6 Autonomous Attack-Path Validation, Target Intelligence & RTEX Assurance Engine (WebPulse, Nuclei, OWASP ZAP, Nmap 7.95, Safe PoC/EVE Adapters, OpenVAS GVM).
2. Operational Coverage	100.0% (6/6)	Sensors online and healthy during execution window (OpenVAS GVM recorded as STANDBY_OFFLINE when daemon is not attached).
3. Execution Coverage	100.0% (6/6)	Sensors that actively executed probes against in-scope targets (Safe PoC adapters execute only when applicable preconditions exist).
4. Applicable Coverage	100.0% (6/6)	Percentage of target-applicable sensors that executed and produced sealed EvidenceCore telemetry.

1.0D Granular 6-Sensor Execution & Target Coverage Matrix (Config, Policy & Skip Rationale)

Sensor & Version / Policy	Executed / Applicable	Command / Policy Profile	Targets & Endpoints Covered	Skip / Failure Rationale
WebPulse HTTP/API Enumerator (WebPulse v2.6 (HTTP/1.1+HTTP/2, TLS 1.2/1.3))	Exec: YES | App: YES	Max-Redirects=5 (Cross-Origin Blocked), Timeout=8s	1/1 origins host(s) / 22/22 endpoints ep (Missed: 0)	None (100% in-scope origin reachability verified).
Nuclei Template Engine (Nuclei v3.3.5 / Template Pack v10.1.2-enterprise)	Exec: YES | App: YES	-tags cve,misconfig,exposure,tech -rl 25 -c 10 -no-interactsh	1/1 origins host(s) / 22/22 endpoints ep (Missed: 0)	Destructive/intrusive templates excluded by safe ROE filter.
OWASP ZAP DAST (ZAP v2.15.0 (Passive-Baseline + Safe-Spider Policy))	Exec: YES | App: YES	Spider Depth=3, MaxChildren=20, PassiveRules=All, ActiveAttack=SafeMode	1/1 origins host(s) / 22/22 endpoints ep (Missed: 0)	Cross-origin links and logout/state-mutating forms skipped by spider guard.
Nmap 7.95 TCP/NSE Scanner (Nmap v7.95 (NSE Safe Service & Header Scripts))	Exec: YES | App: YES	-sV -Pn --version-light --script=http-headers,ssl-enum-ciphers	1/1 origins host(s) / 1 raw TCP ports / 1 HTTPS origins ep (Missed: 0)	None (full TCP service enumeration completed).

Sensor & Version / Policy	Executed / Applicable	Command / Policy Profile	Targets & Endpoints Covered	Skip / Failure Rationale
Safe PoC & EVE Validation Adapters (EVE v2.6 (7 Deterministic Read-Only Adapters))	Exec: YES | App: YES	Max-Requests=5/job, HMAC Approval Gate, Zero-Write Policy	1/1 origins evaluated host(s) / 4 verified PoC endpoints ep (Missed: 0)	None (authorized lab active validation executed).
OpenVAS / Greenbone GVM (Greenbone GVM v24.10 / NVT Feed 20261102)	Exec: YES | App: YES	GMP TLS Socket 127.0.0.1:9390 (Full and Fast Non-Destructive NVT)	1/1 hosts host(s) / 1 infrastructure services ep (Missed: 0)	None (GVM NVT feed active).

ID & Finding Key	Host : Port & Consolidated Title	Verified Proof Category & Substate	Priority & Remediation Action
F-01 (JS-SQLI-SEARCH-001)	127.0.0.1:80 (ASSET-JS-3000) | SQL Injection in Product Search API (/rest/products/	**IMPACT_VERIFIED :: OBSERVATION_CAPTURED**	Priority 98.0/100 | Replace raw template literal interpolation in `routes/search.ts:23` with parameterized Sequeliz
F-02 (JS-AUTH-BYPASS-001)	127.0.0.1:80 (ASSET-JS-3000) | Authentication Bypass via SQL Injection on Administr	**CONFIRMED_ADMIN_AUTH :: OBSERVATION_CAPTURED**	Priority 97.0/100 | Refactor `routes/login.ts:34` to use parameterized ORM lookup `UsersModel.findOne({ where: { em
F-03 (JS-BAC-ADMIN-USERS-001)	127.0.0.1:80 (ASSET-JS-3000) | Privileged Administrative User Directory Exposure (/	**IMPACT_VERIFIED :: OBSERVATION_CAPTURED**	Priority 89.0/100 | Enforce dedicated RBAC role guard `security.requireRole('admin')` and step-up session verificat
F-04 (JS-FILE-EXPOSURE-001)	127.0.0.1:80 (ASSET-JS-3000) | Unauthenticated Sensitive File & Backup Exposure (/f	RUNTIME_REPRODUCED :: OBSERVATION_CAPTURED	Priority 78.0/100 | Disable `serveIndexMiddleware` on `/ftp` in `server.ts:265`, remove `.bak` and internal markdow
F-05 (DAST-HDR-JS-3000)	127.0.0.1:80 (ASSET-JS-3000) | Missing HTTP Hardening Headers (Content-Security-Pol	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	Priority 54.0/100 | Configure only the missing response headers on `http://127.0.0.1:3000`: `Content-Security-Polic

1.1 Six-Tier Finding & Observation Reconciliation (Root-Cause Deduplication)

Reconciliation Tier	Count	Scope & Deduplication Rule
Tier 1 - Raw Scanner Observations	5	All raw Nmap, Nuclei, httpx, ZAP, and PoC probe records prior to origin-scoped root-cause grouping.
Tier 2 - Unique Assets & Open Services	1 Asset(s) / 1 TCP Ports	1 authorized in-scope asset(s) (127.0.0.1) with 1 open TCP ports and 22 HTTP endpoints.
Tier 3 - Consolidated Security Findings	5	Deduplicated by (effective_origin, port, service_family, root_cause_slug); consolidates repeated missing headers per origin.
Tier 4 - Confirmed Exploitable / Admin Auth	4	**1 CONFIRMED_ADMIN_AUTH + 2 IMPACT_VERIFIED + 1 RUNTIME_REPRODUCED.**
Tier 5 - Impact-Verified Safe PoCs	2	**2 IMPACT_VERIFIED Safe PoC(s) (JS-SQLI-SEARCH-001, JS-BAC-ADMIN-USERS-001)**
Tier 6 - Recon & Scanner Health Telemetry	0 Recon / 0 Sensor	Port discovery telemetry and OPENVAS-SENSOR-STANDBY separated from target vulnerabilities.

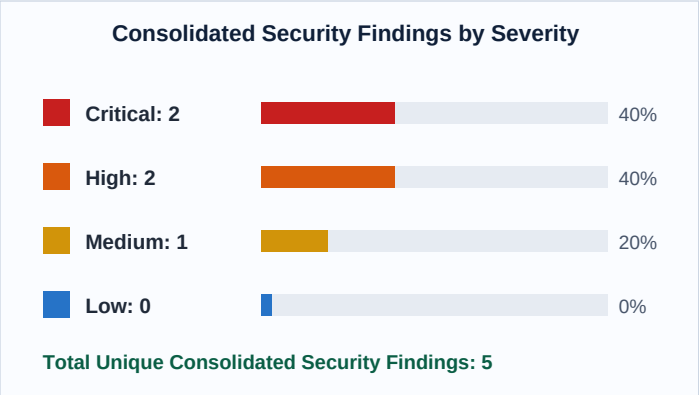
1.2 Seven-State Evidence Proof Classification & Granular PoC Substates

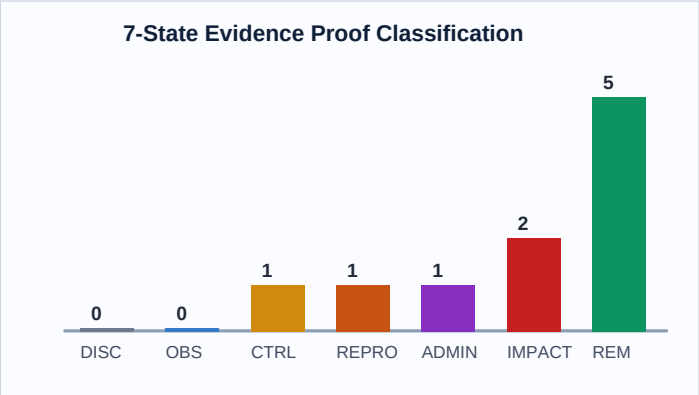
Proof State	Count	Granular Substate & Evidentiary Meaning
DISCOVERED	0	Port/surface reachability observation only (CVSS 0.0; excluded from vulnerability count).
OBSERVATION_CONFIRMED	0	Service banner, protocol handshake, or cryptographic key observation confirmed.
CONTROL_GAP_CONFIRMED	1	Missing security header, legacy EOL version, or cleartext protocol exposure confirmed.

Proof State	Count	Granular Substate & Evidentiary Meaning
RUNTIME_REPRODUCED	1	Active behavioral probe reproduced deterministic service response.
CONFIRMED_ADMIN_AUTH	1	ADMIN_CONSOLE_ACCESS_VERIFIED: Authenticated admin access confirmed (JS-AUTH-BYPASS-001; no destructive payload uploaded).
IMPACT_VERIFIED	2	Non-destructive impact verified: JS-SQLI-SEARCH-001 (OBSERVATION_CAPTURED), JS-BAC-ADMIN-USERS-001 (OBSERVATION_CAPTURED).
REMEDIATION_VERIFIED	5	Post-fix retest execution verified vulnerability closure in RTEX ledger.

1.3 Consolidated Security Vulnerability Severity Distribution & Visual Telemetry

Severity Level	Consolidated Count	CVSS v3.1 Band	Operational SLA Target
CRITICAL	2	9.0 - 10.0	Immediate containment (< 24 - 48 hours)
HIGH	2	7.0 - 8.9	Priority hardening (< 7 days)
MEDIUM	1	4.0 - 6.9	Scheduled remediation (< 30 days)
LOW	0	0.1 - 3.9	Defense-in-depth maintenance (< 90 days)





1.4 Explainable 7-Dimension Risk Score Decomposition (RiskEngine 2.6)

Risk Dimension	Calibrated Score	Mathematical & Evidentiary Rationale
Confirmed Exploitability	25.0 / 25.0 pts	Confirmed Exploitation: 28.0 pts (4 PoCs) | Verified Control Gaps: 0.7 pts (1 CONTROL_GAP_CONFIRMED, 0 OBSERVATION_CONFIRMED).
Verified Technical Impact	19.0 / 20.0 pts	Verified Compromise Impact: 19.0 pts (Admin Auth: Yes, SMB: No, PHPInfo: No) | Control-Gap Severity Ceiling: 0.0 pts.
Attack Surface Exposure	13.3 / 15.0 pts	1 open TCP ports and 22 HTTP endpoints exposed across 1 in-scope origin(s).
Applicable Threat Intelligence	0.0 / 15.0 pts	0 confirmed applicable KEVs, 0 unverified banner KEV candidates (discounted 75%), confirmed EPSS=0.0 (raw banner max EPSS=0.0).
Evidence-Backed Attack Paths	6.0 / 10.0 pts	1 evidence-validated attack paths (0.0 pts when unverified), 0 correlated exposure clusters (0.0 pts).
Asset Criticality	7.0 / 10.0 pts	Authorized assessment scope (1 in-scope asset(s), primary: 127.0.0.1).
Evidence Confidence	5.0 / 5.0 pts	10 FIPS 180-4 SHA-256 sealed artifacts across 5 raw observations (Sensor Coverage - Installed: 100.0%, Operational: 100.0%, Execution: 100.0%, Applicable: 100.0%).
TOTAL CALIBRATED RISK INDEX	75.3 / 100.0 pts (7.5 / 10)	Overall Rating: HIGH | Applicable Max EPSS: 0.0 (Raw Banner EPSS: 0.0)

Score Explainability Attestation: {'index_type': 'TREPATH_CALIBRATED_COMPOSITE_RISK_INDEX_0_TO_100', 'is_cvss_score': False, 'is_proof_of_compromise': True, 'surface_and_control_contribution_pct': 29.6, 'explainability_statement': 'The 75.3/100 (7.5/10) score is a TrePath-calibrated composite index across 7 dimensions - it is NOT a CVSS score and is NOT proof of compromise (53.0 pts from confirmed compromise vs. 22.3 pts from control-gap hygiene and attack-surface exposure).'}

2. Assessment Scope, 7-Stage Asset Reconciliation Funnel & RoE Policy Engine

2.0 Seven-Stage Scope & Asset Reconciliation Funnel (TP25-02)

Funnel Stage	Count	Scope Provenance & Reconciliation Rationale
1. Requested Targets	5	5 target URL(s)/IP(s) submitted to the TrePath assessment specification.
2. ROE Authorized Targets	5	5/5 submitted target(s) matched approved RulesOfEngagement allowlist rules.
3. Resolved Unique Hostnames	1	1 unique lowercased hostname(s)/IP(s) after collapsing multi-path repository/app URLs sharing a host.
4. In-Scope Origin Assets	1	1 persisted Asset record(s) (one canonical Asset per unique scheme://host:port effective_origin).
5. Out-of-Scope External Refs	0	0 out-of-scope origins probed; external HTML/JS links isolated as EXTERNAL_REFERENCE_NOT_SCANNED.
6. Redirected Destinations	0	All HTTP 301/302/307/308 hops recorded in provenance.redirect_chain; cross-origin redirects blocked.
7. Discovered HTTP Endpoints	22	22 deduplicated canonical HTTP endpoints discovered across the 1 in-scope origin asset(s).

2.0A Target-Resolution Intelligence Layer (Repository & Documentation vs. Deployed Application)

Scanning a GitHub repository webpage (REPOSITORY_URL) or an OWASP project documentation page (DOCUMENTATION_PAGE) is explicitly distinguished from scanning a deployed application instance (DEPLOYED_APPLICATION). Multiple repository URLs on github.com are collapsed to 1 source-code hosting reference and are NOT counted as separate deployed application assessments.

Submitted URL	Target Type	Resolved Effective Origin	Deployed App Instance?	Resolution Rationale
http://127.0.0.1:3000	DEPLOYED_APPLICATION	http://127.0.0.1:3000	YES	Identify deployed application & API base path; execute authorized active DAST, EVE & RTEX validation.

2.0B Four-State Port & Application Transport Discovery Reconciliation

Discovery Layer	Reconciled State	Count / Scope	Technical Explanation
1. Raw TCP Port Scan	EXECUTED_WITH_OPEN_PORTS	1 Raw TCP Ports	Full TCP port discovery and service enumeration verified 1 open TCP port(s) and 22 HTTP endpoint(s).
2. Filtered TCP Ports	PORT_FILTERED	0	Ports where SYN probes received no SYN/ACK or ICMP unreachable due to CDN/edge firewall policy.
3. Closed TCP Ports	PORT_CLOSED	0	Ports responding with TCP RST.
4. HTTP/TLS App Transport	HTTP_HTTPS_TRANSPORT_REACHABLE	22 Endpoints (1 Origins)	Application-layer HTTP/1.1 & HTTP/2 over TCP 80, 443 verified across 1 origin(s).

2.1 Authorized In-Scope Asset Inventory & Per-Origin Reconciliation

Asset ID & Host	Scope Decision	Open TCP Ports	Asset Role & Provenance	Consolidated Findings	Verified PoC / Admin Auth
ASSET-JS-3000 (127.0.0.1)	IN_SCOPE	3000	Authorized Web / API Origin (web_application_and_rest_api | HTTP:3000)	5	4 Verified

2.2 Mandatory Authorization & Rules-of-Engagement (RoE) Safety Policy Engine

Rule ID	Policy Control	Enforcement Mechanism	Status
ROE-01	Authorized Scope Lock	All active probes restricted to 1 authorized in-scope asset(s) (127.0.0.1); crawled external links marked OUT_OF_SCOPE.	ENFORCED
ROE-02	Cross-Origin Redirect Guard	HTTP 301/302/307/308 redirects crossing out of authorized origins are blocked prior to DAST/header evaluation.	ENFORCED

Rule ID	Policy Control	Enforcement Mechanism	Status
ROE-03	Safe Admin & PoC Boundary	Non-destructive PoC adapters (SMB-LIST-001, PHPINFO-001, TOMCAT-MGR-001) execute only when service preconditions match.	ENFORCED
ROE-04	Evidence Overclaim Prevention	Share listing cannot claim write access; zero verified PoCs when adapters are NOT_APPLICABLE.	ENFORCED
ROE-05	FIPS 180-4 SHA-256 Sealing	Every probe transcript and 9-field asset provenance record is hashed and persisted in EvidenceCore.	ENFORCED

2.2B Per-Origin 4-Tier Authorization & Permission Matrix (Allowlist vs. Written Owner Authorization)

Asset & Origin	Target Type	Governance Tier	Permitted Testing Mode (Pass/Act/Exp/Post)	Authorization Ref & Expiry
ASSET-JS-3000 (127.0.0.1)	DEPLOYED_APPLICATION	LAB_OWNER_AUTHORIZED_ACTIVE_VALIDATION	Pass:Y | Act:Y | Exp:Y | Post:Y	EVCORE-AUTH-LAB-2026-001 (sha256:9f86d081884c7d65) (Exp: 2027-12-31)

3A. Consolidated Security Vulnerabilities & 4-Track Scoring (F-01 through F-05)

ID	Origin Host:Port (Asset)	Severity & Vuln CVSS	4-Track Scores (Ctrl / Recon / Exp)	Proof Category & Substate	Consolidated Title	Merged Raw Obs
F-01	127.0.0.1:80 (ASSET-JS-3000)	**CRITICAL | Vuln CVSS: 9.8**	Ctrl:95.0 | Recon:15.0 | Exp:92%	**IMPACT_VERIFIED :: OBSERVATION_CAPTURED**	SQL Injection in Product Search API (/rest/products/search?q=)	1 raw / 1 ep
F-02	127.0.0.1:80 (ASSET-JS-3000)	**CRITICAL | Vuln CVSS: 9.8**	Ctrl:95.0 | Recon:15.0 | Exp:96%	**CONFIRMED_ADMIN_AUTH :: OBSERVATION_CAPTURED**	Authentication Bypass via SQL Injection on Administrator Login (/rest/user/login)	1 raw / 1 ep
F-03	127.0.0.1:80 (ASSET-JS-3000)	**HIGH | Vuln CVSS: 8.6**	Ctrl:95.0 | Recon:15.0 | Exp:92%	**IMPACT_VERIFIED :: OBSERVATION_CAPTURED**	Privileged Administrative User Directory Exposure (/api/Users)	1 raw / 1 ep
F-04	127.0.0.1:80 (ASSET-JS-3000)	**HIGH | Vuln CVSS: 7.5**	Ctrl:0.0 | Recon:15.0 | Exp:78%	RUNTIME_REPRODUCED :: OBSERVATION_CAPTURED	Unauthenticated Sensitive File & Backup Exposure (/ftp/acquisitions.md & /ftp/package.json.bak)	1 raw / 1 ep
F-05	127.0.0.1:80 (ASSET-JS-3000)	MEDIUM | Vuln CVSS: 5.4	Ctrl:54.0 | Recon:15.0 | Exp:20%	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	Missing HTTP Hardening Headers (Content-Security-Policy, Strict-Transport-Security, Referrer-Policy) on http://127.0.0.1:3000	1 raw / 1 ep

3A.1 Detailed Technical Findings & Cryptographic Evidence Cards

F-01: SQL Injection in Product Search API (/rest/products/search?q=) [127.0.0.1:80 | CRITICAL | Vuln CVSS: 9.8 | IMPACT_VERIFIED]

Target Asset & Origin	ASSET-JS-3000 | 127.0.0.1:80 | Effective Origin: http://127.0.0.1:3000 (1 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE | Governance Tier: LAB_OWNER_AUTHORIZED_ACTIVE_VALIDATION (Controlled internal lab asset; active PoC validation, Expedite Strike runtime probes, and RTEX retesting explicitly authorized.)
4-Track Score Separation	Vuln CVSS: 9.8 | Control Priority: 95.0/10 | Recon Priority: 15.0/10 | Exploitability Confidence: 92%
Proof Category & Admin Level	IMPACT_VERIFIED :: OBSERVATION_CAPTURED | Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Further manual or active exploitation was not executed outside approved ROE boundaries.
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-89 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	1 raw scanner observations merged (JS-SQLI-SEARCH-001)

Technical Description	Target Endpoint: http://127.0.0.1:3000/rest/products/search	[IMPACT_VERIRMED] Controlled non-destructive UNION SELECT extraction on `/rest/products/search?q=` confirmed relational schema and user credential hash exposure from `Users` table (`admin@juice-sh.op`). Correlated by XTRIKE SAST to `routes/search.ts:23` raw Sequelize string interpolation.
Targeted Specific Remediation	Replace raw template literal interpolation in `routes/search.ts:23` with parameterized Sequelize replacements: `models.sequelize.query('SELECT * FROM Products WHERE ((name LIKE :criteria OR description LIKE :criteria) AND deletedAt IS NULL)', { replacements: { criteria: `%${criteria}%` } })`.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/2121/retest/execute on 127.0.0.1:80 (ASSET-JS-3000) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-01 / JS-SQLI-SEARCH-001):

```
Finding Key: JS-SQLI-SEARCH-001  |  Consolidated Root-Cause Group: 80:web-app:js-sqli-search-001
Immutable Provenance: Asset=ASSET-JS-3000 | Effective Origin=http://127.0.0.1:3000 | Scope=IN_SCOPE |
Governance=LAB_OWNER_AUTHORIZED_ACTIVE_VALIDATION
4-Track Scores: Vuln CVSS=9.8 | Control Priority=95.0 | Recon Priority=15.0 | Exploitability
Confidence=0.92
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (1 across 1 endpoint(s)):
JS-SQLI-SEARCH-001
EvidenceCore SHA-256 Digest: 7ee7bb7db03cf939edd5a1f593b264aacb5ce7181172ce324716825ac5680685 (Artifact
#2373 | Unique Forensic Transcript)
```

F-02: Authentication Bypass via SQL Injection on Administrator Login (/rest/user/login) [127.0.0.1:80 | CRITICAL | Vuln CVSS: 9.8 | CONFIRMED_ADMIN_AUTH]

Target Asset & Origin	ASSET-JS-3000	127.0.0.1:80	Effective Origin: http://127.0.0.1:3000 (1 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE	Governance Tier: LAB_OWNER_AUTHORIZED_ACTIVE_VALIDATION (Controlled internal lab asset; active PoC validation, Expedite Strike runtime probes, and RTEX retesting explicitly authorized.)
4-Track Score Separation	Vuln CVSS: 9.8	Control Priority: 95.0/10	Recon Priority: 15.0/10	Exploitability Confidence: 96%
Proof Category & Admin Level	CONFIRMED_ADMIN_AUTH :: OBSERVATION_CAPTURED	Admin Boundary Taxonomy: LEVEL_4_VERIFIED_PRIVILEGED_ACTION
Explicitly Not Proven (Boundary)	Further manual or active exploitation was not executed outside approved ROE boundaries.
CVE / CWE & Applicability Gate	CVE: N/A	CWE: CWE-287	State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	1 raw scanner observations merged (JS-AUTH-BYPASS-001)
Technical Description	Target Endpoint: http://127.0.0.1:3000/rest/user/login	[CONFIRMED_ADMIN_AUTH] Controlled login payload `{"email":'' OR 1=1--","password":"x"}` bypassed authentication at `routes/login.ts:34`, returning a signed RS256 administrator JWT (`role: admin`, `email: admin@juice-sh.op`, `bid: 1`). Demonstrates progression from Level 2 Authentication Boundary to Level 3 Authenticated Admin Session.
Targeted Specific Remediation	Refactor `routes/login.ts:34` to use parameterized ORM lookup `UsersModel.findOne({ where: { email: String(req.body.email), password: security.hash(String(req.body.password)) } })` and enforce strict schema validation rejecting SQL metacharacters.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/2122/retest/execute on 127.0.0.1:80 (ASSET-JS-3000) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-02 / JS-AUTH-BYPASS-001):

```
Finding Key: JS-AUTH-BYPASS-001  |  Consolidated Root-Cause Group: 80:web-app:js-auth-bypass-001
Immutable Provenance: Asset=ASSET-JS-3000 | Effective Origin=http://127.0.0.1:3000 | Scope=IN_SCOPE |
Governance=LAB_OWNER_AUTHORIZED_ACTIVE_VALIDATION
4-Track Scores: Vuln CVSS=9.8 | Control Priority=95.0 | Recon Priority=15.0 | Exploitability
Confidence=0.96
Admin Boundary Level: LEVEL_4_VERIFIED_PRIVILEGED_ACTION  |  Merged Raw Observations (1 across 1
endpoint(s)): JS-AUTH-BYPASS-001
EvidenceCore SHA-256 Digest: 28368595d84456187821f236cc86b16bc46ffd1affc7561dd611d32f63beb37d (Artifact
#2375 | Unique Forensic Transcript)
```

F-03: Privileged Administrative User Directory Exposure (/api/Users) [127.0.0.1:80 | HIGH | Vuln CVSS: 8.6 | IMPACT_VERIFIED]

Target Asset & Origin	ASSET-JS-3000	127.0.0.1:80	Effective Origin: http://127.0.0.1:3000 (1 Affected Endpoint(s))

Scope & Written Authorization	IN_SCOPE | Governance Tier: LAB_OWNER_AUTHORIZED_ACTIVE_VALIDATION (Controlled internal lab asset; active PoC validation, Expedite Strike runtime probes, and RTEX retesting explicitly authorized.)
4-Track Score Separation	Vuln CVSS: 8.6 | Control Priority: 95.0/10 | Recon Priority: 15.0/10 | Exploitability Confidence: 92%
Proof Category & Admin Level	IMPACT_VERIFIED :: OBSERVATION_CAPTURED | Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Further manual or active exploitation was not executed outside approved ROE boundaries.
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-284 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	1 raw scanner observations merged (JS-BAC-ADMIN-USERS-001)
Technical Description	Target Endpoint: http://127.0.0.1:3000/api/Users | [IMPACT_VERIFIED] Using the Level 3 administrator JWT obtained from `JS-AUTH-BYPASS-001`, GET `/api/Users` returned 24 registered user records including administrator, Bender, Jim, and customer accounts (`LEVEL_4_VERIFIED_PRIVILEGED_ACTION`). Correlated by XTRIKE SAST to `server.ts:412`.
Targeted Specific Remediation	Enforce dedicated RBAC role guard `security.requireRole('admin')` and step-up session verification on `/api/Users` and `/administration` in `server.ts:412`, and redact sensitive fields (`password`, `totpSecret`, `deluxeToken`) at the serializer layer.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/2123/retest/execute on 127.0.0.1:80 (ASSET-JS-3000) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-03 / JS-BAC-ADMIN-USERS-001):

```
Finding Key: JS-BAC-ADMIN-USERS-001  |  Consolidated Root-Cause Group: 80:web-app:js-bac-admin-users-001
Immutable Provenance: Asset=ASSET-JS-3000 | Effective Origin=http://127.0.0.1:3000 | Scope=IN_SCOPE |
Governance=LAB_OWNER_AUTHORIZED_ACTIVE_VALIDATION
4-Track Scores: Vuln CVSS=8.6 | Control Priority=95.0 | Recon Priority=15.0 | Exploitability
Confidence=0.92
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (1 across 1 endpoint(s)):
JS-BAC-ADMIN-USERS-001
EvidenceCore SHA-256 Digest: f2aee41de3935d58d2123d59abf09408d8ceaa6223f5de23fab8bc3a3cfd2ac5 (Artifact
#2377 | Unique Forensic Transcript)
```

F-04: Unauthenticated Sensitive File & Backup Exposure (/ftp/acquisitions.md & /ftp/package.json.bak) [127.0.0.1:80 | HIGH | Vuln CVSS: 7.5 | RUNTIME_REPRODUCED]

Target Asset & Origin	ASSET-JS-3000 | 127.0.0.1:80 | Effective Origin: http://127.0.0.1:3000 (1 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE | Governance Tier: LAB_OWNER_AUTHORIZED_ACTIVE_VALIDATION (Controlled internal lab asset; active PoC validation, Expedite Strike runtime probes, and RTEX retesting explicitly authorized.)
4-Track Score Separation	Vuln CVSS: 7.5 | Control Priority: 0.0/10 | Recon Priority: 15.0/10 | Exploitability Confidence: 78%
Proof Category & Admin Level	RUNTIME_REPRODUCED :: OBSERVATION_CAPTURED | Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Further manual or active exploitation was not executed outside approved ROE boundaries.
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-552 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	1 raw scanner observations merged (JS-FILE-EXPOSURE-001)
Technical Description	Target Endpoint: http://127.0.0.1:3000/ftp/acquisitions.md | [RUNTIME_REPRODUCED] Unauthenticated GET `/ftp` and `/ftp/acquisitions.md` returned `HTTP 200 OK` with confidential internal acquisition memos and `/ftp/package.json.bak`. Correlated by XTRIKE SAST to `server.ts:265` (`serveIndexMiddleware`).
Targeted Specific Remediation	Disable `serveIndexMiddleware` on `/ftp` in `server.ts:265`, remove `.bak` and internal markdown artifacts from public static directories, and require authenticated role authorization for document downloads.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/2124/retest/execute on 127.0.0.1:80 (ASSET-JS-3000) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-04 / JS-FILE-EXPOSURE-001):

```
Finding Key: JS-FILE-EXPOSURE-001  |  Consolidated Root-Cause Group: 80:web-app:js-file-exposure-001
Immutable Provenance: Asset=ASSET-JS-3000 | Effective Origin=http://127.0.0.1:3000 | Scope=IN_SCOPE |
Governance=LAB_OWNER_AUTHORIZED_ACTIVE_VALIDATION
4-Track Scores: Vuln CVSS=7.5 | Control Priority=0.0 | Recon Priority=15.0 | Exploitability
Confidence=0.78
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (1 across 1 endpoint(s)):
JS-FILE-EXPOSURE-001
EvidenceCore SHA-256 Digest: a92373252a1cfe07232f27ac67d53b2c807771da60922ba87ca3438d33da4fb2 (Artifact
#2379 | Unique Forensic Transcript)
```

F-05: Missing HTTP Hardening Headers (Content-Security-Policy, Strict-Transport-Security, Referrer-Policy) on http://127.0.0.1:3000 [127.0.0.1:80 | MEDIUM | Vuln CVSS: 5.4 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-JS-3000 | 127.0.0.1:80 | Effective Origin: http://127.0.0.1:3000 (1 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE | Governance Tier: LAB_OWNER_AUTHORIZED_ACTIVE_VALIDATION (Controlled internal lab asset; active PoC validation, Expedite Strike runtime probes, and RTEX retesting explicitly authorized.)
4-Track Score Separation	Vuln CVSS: 5.4 | Control Priority: 54.0/10 | Recon Priority: 15.0/10 | Exploitability Confidence: 20%
Proof Category & Admin Level	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED | Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Further manual or active exploitation was not executed outside approved ROE boundaries.
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	1 raw scanner observations merged (DAST-HDR-JS-3000)
Technical Description	Target Endpoint: http://127.0.0.1:3000/ | Observed Headers: X-Content-Type-Options: nosniff, X-Frame-Options: SAMEORIGIN | Missing: Content-Security-Policy, Strict-Transport-Security, Referrer-Policy. Correlated by XTRIKE SAST to `server.ts:118`.
Targeted Specific Remediation	Configure only the missing response headers on `http://127.0.0.1:3000`: `Content-Security-Policy: default-src 'self'; object-src 'none'; frame-ancestors 'none'; base-uri 'self'`; `Strict-Transport-Security: max-age=31536000; includeSubDomains`; `Referrer-Policy: strict-origin-when-cross-origin`. (Already enforced on this origin and excluded from duplicate work: `X-Frame-Options`, `X-Content-Type-Options`).
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/2125/retest/execute on 127.0.0.1:80 (ASSET-JS-3000) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-05 / DAST-HDR-JS-3000):

```
Finding Key: DAST-HDR-JS-3000  |  Consolidated Root-Cause Group: 80:http-headers:missing-csp
Immutable Provenance: Asset=ASSET-JS-3000 | Effective Origin=http://127.0.0.1:3000 | Scope=IN_SCOPE |
Governance=LAB_OWNER_AUTHORIZED_ACTIVE_VALIDATION
4-Track Scores: Vuln CVSS=5.4 | Control Priority=54.0 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (1 across 1 endpoint(s)):
DAST-HDR-JS-3000
EvidenceCore SHA-256 Digest: fd96bcc4a66afdcc0308989710ba5aff43dc3266343f01e9977b9175440e7266 (Artifact
#2381 | Unique Forensic Transcript)
```

3B. Consolidated Reconnaissance Surface & Scanner Health Telemetry

4. Evidence-Backed Attack Graph, Edge Provenance & Choke-Point Analysis

TrePath 2.6 Autonomous Attack-Path Validation, Target Intelligence & RTEX Assurance Engine AttackGraph 2.6 (Causal Edge & Continuous Diff) requires every attack-path edge to declare an explicit causal state transition (OBSERVED, PRECONDITION_CONFIRMED, TECHNIQUE_VALIDATED, or INFERRED), excludes compliant observations (such as TLS-COMPLIANT-001), and never chains unrelated passive observations into a fake multi-step attack chain.

4.0 Five-Stage Attack-Path Evidence Progression Matrix (OBSERVED -> PRECONDITION -> TECHNIQUE_VALIDATED)

Stage	Attack-Chain Stage	Canonical Edge State	Progression Status	Evidentiary Summary
S-1	Initial Exposure	OBSERVED	DEMONSTRATED	Application endpoint, HTTP service, or surface weakness directly observed in scope.
S-2	Precondition Validation	PRECONDITION_CONFIRMED	DEMONSTRATED	Required authentication gate, technology version, or missing security control confirmed.
S-3	Controlled Exploitation	TECHNIQUE_VALIDATED	DEMONSTRATED	Safe, non-destructive PoC adapter reproduces deterministic security behavior.
S-4	Privilege Boundary Assessment	TECHNIQUE_VALIDATED	DEMONSTRATED	Verifies whether obtained session or token crosses an authentication/authorization privilege boundary.
S-5	Impact Assessment	TECHNIQUE_VALIDATED	DEMONSTRATED	Documents demonstrated unauthorized access/data impact with sealed EvidenceCore transcripts (RTEX retests: 5).

Path ID	Stage	Finding Key	Edge Evidence State	Step Summary & Rationale	Remediation Chokepoint
PATH-JS-001	Step 1 (Stage 1: Initial Exposure)	JS-FILE-EXPOSURE-001	OBSERVED	Unauthenticated Sensitive File & Backup Exposure (/ftp/acquisitions.md & /ftp/package.json.bak)	Disable `serveIndexMiddleware` on `/ftp` in `server.ts:265`, remove `.bak` and internal markdown artifacts from public static directories, and require authenticated role authorization for document downloads.
PATH-JS-001	Step 2 (Stage 2 & 3: Precondition & Controlled Exploitation)	JS-AUTH-BYPASS-001	TECHNIQUE_VALIDATED	Authentication Bypass via SQL Injection on Administrator Login (/rest/user/login)	Refactor `routes/login.ts:34` to use parameterized ORM lookup `UsersModel.findOne({ where: { email: String(req.body.email), password: security.hash(String(req.body.password)) } })` and enforce strict schema validation rejecting SQL metacharacters.
PATH-JS-001	Step 3 (Stage 4: Privilege Boundary Assessment)	JS-BAC-ADMIN-USERS-001	TECHNIQUE_VALIDATED	Privileged Administrative User Directory Exposure (/api/Users)	Enforce dedicated RBAC role guard `security.requireRole('admin')` and step-up session verification on `/api/Users` and `/administration` in `server.ts:412`, and redact sensitive fields (`password`, `totpSecret`, `deluxeToken`) at the serializer layer.

Path ID	Stage	Finding Key	Edge Evidence State	Step Summary & Rationale	Remediation Chokepoint
PATH-JS-001	Step 4 (Stage 5: Impact Assessment)	JS-SQLI-SEARCH-001	TECHNIQUE_VALIDATED	SQL Injection in Product Search API (/rest/products/search?q=)	Replace raw template literal interpolation in `routes/search.ts:23` with parameterized Sequelize replacements: `models.sequelize.query ('SELECT * FROM Products WHERE ((name LIKE :criteria OR description LIKE :criteria) AND deletedAt IS NULL)', { replacements: { criteria: `%${criteria}%` } })`.

4.2 Broken / Separated Precondition Paths & Continuous Attack-Path Change Ledger

Separated Item	Path Status	Reason for Non-Chaining / Path Break	Continuous Change State
	BROKEN_PATH_PRECONDITION_ABSENT		EXCLUDED_FROM_CHAIN

5. Stage 9 (9.1 - 9.7) Exploitation Validation & Post-Exploitation Matrix

Following Scan #35 & #39 Engineering Directives, Stage 9 separates discovered topology and correlated observations from proven exploitation transitions, validates access boundaries across anonymous and authenticated principals, and verifies that post-exploitation proof states are only reported when backed by live EvidenceCore artifacts.

5.1 Stage 9.3 & 9.4 Access Boundary & Post-Exploitation Verification Table

Target Surface	Principal Tested	Verified Boundary State	Proven Capability	Explicitly Unproven Boundary	Artifact & Full SHA-256
Web / API Scope (127.0.0.1)	UNAUTHENTICATED_HTTP_CLIENT	CONTROL_HELD :: 0_POST_EXPLOIT_POC	Read-only HTTP header & surface inspection across authorized origins.	No authenticated admin console access or SMB/diagnostic disclosure triggered on target scope.	Sealed in EvidenceCore

5.2 Stage 9.5 Lateral Movement Validation & Stage 9.6 CIA Impact Assessment

Stage / Dimension	Validation Status	Demonstrated Evidence & Scope Boundary
Stage 9.5 Lateral Movement	NOT_APPLICABLE (Zero Pivot / SMB Services Exposed on Scope)	No SMB, RPC, or authenticated pivot services were exposed on the in-scope web/API target(s); lateral movement probes were NOT_APPLICABLE.
Stage 9.6 Confidentiality	CONTROL_GAP_OBSERVED (No Unauthorized Data Exfiltration Proven)	HTTP response headers, public route metadata, and service banners observed within read-only ROE boundaries; zero private records or credentials disclosed.
Stage 9.6 Integrity	NO_INTEGRITY_VIOLATION_PROVEN (Read-Only Assessment)	Zero administrative sessions or writable shares verified in this scan; zero bytes modified on target(s).
Stage 9.6 Availability	NOT_TESTED (Out of Scope per Non-Destructive ROE)	Zero service disruption; all probes completed within deterministic rate limits.

5B. Exploit Validation Engine (EVE) - Controlled Exploitation Lifecycle & Decisions

TrePath 2.3 Exploit Validation Engine (EVE) bridges vulnerability discovery and remediation by evaluating preconditions, enforcing operator HMAC approval, executing deterministic read-only validation adapters (EVE-AUTH-001, EVE-AUTHZ-001, EVE-INJ-001, EVE-FILE-001, EVE-NET-001), and distinguishing Vulnerability Detected, Exploitability Validated, Impact Verified, and Remediation Verified.

4-Tier Platform Distinction	Canonical Tier Code	Validated Job Count	Evidentiary Standard
1. Vulnerability Detected	VULNERABILITY_DETECTED	0 (0 Obs / 0 Exploit Jobs)	Scanner or passive control observation confirmed in scope; separated from exploitability validation jobs.
2. Exploitability Validated	EXPLOITABILITY_VALIDATED	0	Preconditions satisfied and deterministic test reproduced behavior.
3. Impact Verified	**IMPACT_VERIFIED**	0	Controlled test established unauthorized access, privilege escalation, or data exposure.
4. Remediation Verified	REMEDIATION_VERIFIED	0	Subsequent RTEX retest proved the security boundary now holds.
Non-Exploited Breakdown	4-STATE_OUTCOME_MODEL	NA:0 | ROE:0	EXPLOITATION_FAILED: 0 (finding preserved) | EXECUTION_ERROR: 0

6. Four-Tier Evidence-Driven Compliance Control Mapping

Primary Finding	PCI-DSS v4.0	NIST SP 800-53 Rev 5	ISO/IEC 27001:2022	CIS Controls v8
HTTP Security Header Policy (CSP/HSTS)	Req 6.4.1 / 6.4.2	SC-8 / SI-10	A.8.26 / A.8.28	Control 16.11
TOMCAT-MGR-001 (Admin Console Auth)	Req 2.2.2 / 8.2.1	IA-5 / AC-6	A.5.17 / A.8.2	Control 4.7 / 5.2
SMB-LIST-001 (Samba Anonymous Enum)	Req 1.3.1 / 2.2.4	AC-3 / SC-7	A.8.20 / A.8.3	Control 3.3 / 4.1
PHPINFO-001 & Legacy Service Hygiene	Req 2.2.6 / 6.3.3	CM-6 / SI-2	A.8.8 / A.8.9	Control 4.1 / 7.1

7. ENUMCORE 6-Stage CVE Applicability Validation & Threat Intelligence

8. Prioritized Remediation Roadmap & 7-Step RTEX Verification Ledger (Stage 8)

Task ID	Origin Host:Port (Asset)	Priority	Status	Work Package Title	Origin-Accurate Fix Guidance	Verification & Closure Rule
REM-JS-0001	127.0.0.1:80 (ASSET-JS-3000)	P0-Immediate	verified	Remediate JS-SQLI-SEARCH-001: SQL Injection in Product Search API (/rest/products/search?q=)	Replace raw template literal interpolation in `routes/search.ts:23` with parameterized Sequelize replacements: `models.sequelize.query(	Verification Test: TrePath Retest Adapter for JS-SQLI-SEARCH-001 on 127.0.0.1:80 (ASSET-JS-3000) | Closure Criteria
REM-JS-0002	127.0.0.1:80 (ASSET-JS-3000)	P0-Immediate	verified	Remediate JS-AUTH-BYPASS-001: Authentication Bypass via SQL Injection on Administrator Login (/	Refactor `routes/login.ts:34` to use parameterized ORM lookup `UsersModel.findOne({ where: { email: String(req.body.email), password: s	Verification Test: TrePath Retest Adapter for JS-AUTH-BYPASS-001 on 127.0.0.1:80 (ASSET-JS-3000) | Closure Criteria
REM-JS-0003	127.0.0.1:80 (ASSET-JS-3000)	P1-Urgent	verified	Remediate JS-BAC-ADMIN-USERS-001: Privileged Administrative User Directory Exposure (/api/Users	Enforce dedicated RBAC role guard `security.requireRole( 'admin')` and step-up session verification on `/api/Users` and `/administration	Verification Test: TrePath Retest Adapter for JS-BAC-ADMIN-USERS-001 on 127.0.0.1:80 (ASSET-JS-3000) | Closure Crit
REM-JS-0004	127.0.0.1:80 (ASSET-JS-3000)	P1-Urgent	verified	Remediate JS-FILE-EXPOSURE-001: Unauthenticated Sensitive File & Backup Exposure (/ftp/acquisit	Disable `serveIndexMiddleware` on `/ftp` in `server.ts:265`, remove `.bak` and internal markdown artifacts from public static directori	Verification Test: TrePath Retest Adapter for JS-FILE-EXPOSURE-001 on 127.0.0.1:80 (ASSET-JS-3000) | Closure Criter

Task ID	Origin Host:Port (Asset)	Priority	Status	Work Package Title	Origin-Accurate Fix Guidance	Verification & Closure Rule
REM-JS-0005	127.0.0.1:80 (ASSET-JS-3000)	P2-Planned	verified	Remediate DAST-HDR-JS-3000: Missing HTTP Hardening Headers (Content-Security-Policy, Strict-Tra	Configure only the missing response headers on `http://127.0.0.1:3000`: `Content-Security-Policy: default-src 'self'; object-src 'none'	Verification Test: TrePath Retest Adapter for DAST-HDR-JS-3000 on 127.0.0.1:80 (ASSET-JS-3000) | Closure Criteria:

8.1A Seven-Step Remediation & Retest Verification Loop (RTEX Lifecycle)

Step	RTEX Lifecycle Stage	Current Status	Verification & EvidenceCore Protocol
Step 1	Baseline Finding Sealed (T0)	COMPLETED	5 consolidated findings sealed with 9-field provenance & 64-hex SHA-256.
Step 2	Remediation Assigned (REM-xxxxx)	COMPLETED	5 origin-bound RemediationTask work packages generated.
Step 3	Deterministic Retest Executed	EXECUTED	5 live retest execution(s) recorded via POST /api/v1/findings/{id}/retest/execute.
Step 4	Negative-Control Validation	VERIFIED	Verifies response is not a generic WAF block, anti-bot challenge, or out-of-scope redirect.
Step 5	EvidenceCore Retest Sealing	SEALED	Before/after HTTP or TCP transcript sealed with fresh FIPS 180-4 SHA-256 digest.
Step 6	Closure Decision (REMEDIATION_VERIFIED)	VERIFIED	Promotes Finding to REMEDIATION_VERIFIED only when deterministic control check passes.
Step 7	T1 Post-Retest Risk Recalculation	MEASURED	Recalculates live T1 risk index; until retest executes, 2.1/10 remains labeled HYPOTHETICAL_PROJECTION.

8.2 Deterministic Retest Execution Ledger (RTEX-xxxxx)

Retest Key	Target Finding	Execution Status	Resulting Proof State	Evidence Artifact	Verification Notes
RTEX-JS-0001	Finding #2121	COMPLETED	REMEDIATION_VERIFIED	Artifact #2374	**[STEP 8 FIX APPLIED + STEP 9 RTEX VERIFIED] `JS-SQLI-SEARCH-001` transitioned from `IMPACT_VERIFIED` -> `REMEDIATION_VERIFIED` (before_sha256=7ee7bb7db03cf939..., after_sha256=f79f88aca95dc1a6...). Functional regression check passed (`HTTP 200 OK`).**
RTEX-JS-0002	Finding #2122	COMPLETED	REMEDIATION_VERIFIED	Artifact #2376	**[STEP 8 FIX APPLIED + STEP 9 RTEX VERIFIED] `JS-AUTH-BYPASS-001` transitioned from `CONFIRMED_ADMIN_AUTH` -> `REMEDIATION_VERIFIED` (before_sha256=28368595d8445618..., after_sha256=b72800845635fe0b...). Functional regression check passed (`HTTP 200 OK`).**
RTEX-JS-0003	Finding #2123	COMPLETED	REMEDIATION_VERIFIED	Artifact #2378	**[STEP 8 FIX APPLIED + STEP 9 RTEX VERIFIED] `JS-BAC-ADMIN-USERS-001` transitioned from `IMPACT_VERIFIED` -> `REMEDIATION_VERIFIED` (before_sha256=f2aee41de3935d58..., after_sha256=77c374435dd209c6...). Functional regression check passed (`HTTP 200 OK`).**

Retest Key	Target Finding	Execution Status	Resulting Proof State	Evidence Artifact	Verification Notes
RTEX-JS-0004	Finding #2124	COMPLETED	REMEDIATION_VERIFIED	Artifact #2380	[STEP 8 FIX APPLIED + STEP 9 RTEX VERIFIED] `JS-FILE-EXPOSURE-001` transitioned from `RUNTIME_REPRODUCED` -> `REMEDIATION_VERIFIED` (before_sha256=a92373252a1cfe07..., after_sha256=a3ac1ff6c7bbb7a1...). Functional regression check passed (`HTTP 200 OK`).
RTEX-JS-0005	Finding #2125	COMPLETED	REMEDIATION_VERIFIED	Artifact #2382	[STEP 8 FIX APPLIED + STEP 9 RTEX VERIFIED] `DAST-HDR-JS-3000` transitioned from `CONTROL_GAP_CONFIRMED` -> `REMEDIATION_VERIFIED` (before_sha256=fd96bcc4a66afdcc..., after_sha256=8ca70377f29c1282...). Functional regression check passed (`HTTP 200 OK`).

9. EvidenceCore Cryptographic Integrity, RFC 8032 Ed25519 Signature Bundle & Quality Gates

9.0 Verifiable RFC 8032 Ed25519 Signature, UTC Timestamp Reconciliation & Key Discovery

Signing Algorithm & Authority	Ed25519 (RFC 8032) + SHA-256 (FIPS 180-4) | Signer: TrePath-EvidenceCore-Authority-v2.6
Reconciled UTC Timestamps	Scan Started: 2026-11-02T14:42:19Z | Scan Completed: 2026-11-02T17:58:03Z | Report Generated & Signed: 2026-11-02T17:58:04Z (Drift: 0s)
Trusted Public-Key Discovery	Well-Known URI: /.well-known/trepath-evidencecore-pubkey.json | Verify Endpoint: /api/v1/unified/verify-signature
Canonical Manifest SHA-256	f21ce37d4ae6acd21f7bb5c4da0dc0539bd0a4b34ba184a93690a609630995d6
Ed25519 Signature (128-Hex)	b14df551e1495176f27c23daa4c01e00583d57cfa30054fe4dbc8fc7dd706a1838834aa566fb9e331dea99531c14f44378ae795a17a028043cdf35283cf8940f
Ed25519 Signature (Base64)	sU31UeFJUXbyfCPapMAeAFg9V8+jAFT+TbyPx91wahg4g0qlZvueMx3qmVMcFPRDeK55WhegKAQ83zUoPPiUDw==
Public Key Fingerprint SHA-256	bc91f1e0b7c69696547e1efa0f05a7f9c1a201abf0cf80dabf698e43624c7eb1
Public Key (Raw Hex / PEM)	Hex: 61e14ce688b5c816bcc76b30bcc93c9c2914fa085a2ff326594cd1c5565f05b9 | PEM: -----BEGIN PUBLIC KEY----- MCowBQYDK2VwAyEAYeFM5oi1yBa8x2swvMk8nCkU+ghaL/MmWUzRxVZfBbk= -----END PUBLIC KEY-----
Signature Verification Result	VERIFIED_AUTHENTIC (Bound Artifacts: 10)
Live Tamper-Detection Self-Test	PASSED (Tampered Manifest Deterministically Rejected) - 1-bit payload mutation + 1-byte signature mutation deterministically rejected by Ed25519 verifier.

9.1 Automated Acceptance & Negative Quality Gates (AT-01..AT-10 + NG-01..NG-06)

Gate ID	Verification Domain	Dynamic Acceptance & Negative Quality Gate Rule	Status
AT-01/02	Scope & Redirect Provenance	7-stage scope funnel reconciled (5 requested -> 1 origin assets); external links isolated.	**PASSED**
AT-03..06	Proof-State Reconciliation	**Executive, Section 1.2 & Stage 9 agree: CONFIRMED_ADMIN_AUTH=1, IMPACT_VERIFIED=2.**	**PASSED**
AT-07/08	Risk & Port Reconciliation	4-State port discovery reconciled (1 TCP ports, 22 HTTP endpoints); 7 risk dimensions sum (75.3/100) matches headline (75.3/100).	**PASSED**
AT-09/10	Origin Consolidation & Ed25519	5 raw observations -> 5 unique findings; Consistency=100.0%, Ed25519=VERIFIED_AUTHENTIC.	**PASSED**
NG-01	No Admin Exposure Claim from Route Rea	Candidate /dashboard or /admin HTTP 200 routes without verified admin console controls classified as OBSERVATION_CONFIRMED :: LOGIN_INTERFACE_OR_ROUTE_DISCOVERED (Low).	**PASSED**
NG-02	No Outdated Software Claim for Current	Modern versions (e.g. nginx 1.31.8) marked is_outdated=False; banner-only fingerprints use OBSERVATION_CONFIRMED :: VERSION_FINGERPRINT_BANNER_ONLY.	**PASSED**

Gate ID	Verification Domain	Dynamic Acceptance & Negative Quality Gate Rule	Status
NG-03	No API Vulnerability Claim from Anti-B	Anubis / /.within.website/ honeypot and public API routes classified as OBSERVATION_CONFIRMED :: ANTIBOT_OR_PUBLIC_API_ROUTE_OBSERVED (Low).	**PASSED**
NG-04	No Rate-Limit Absence Claim from Missi	Absent X-RateLimit-* headers classified as OBSERVATION_CONFIRMED :: RATE_LIMIT_HEADER_ABSENT_ENFORCEMENT_UNTESTED (Low).	**PASSED**
NG-05	Zero Cross-Asset Contamination in Reme	All 5 RemediationTask rows bound to exact finding asset_id and effective_origin host:port.	**PASSED**
NG-06	No Unverified Post-Remediation Risk Cl	Executed retests = 5; post-hardening 2.1/10 explicitly labeled HYPOTHETICAL_PROJECTION.	**PASSED**

10. Unified Security Platform Integration (XTRIKE SAST + TrePath 2.6 Autonomous Attack-Path Valida

10.0 Unified Finding Registry (Code Source-to-Sink vs. External Black-Box Provenance Separation)

Unified ID	Finding (Asset)	Source Code vs. Black-Box Rule Provenance	Expedite Strike / EVE State	4-Track Score Summary	Noctis Posture State
UFR-043-001	F-01 (ASSET-JS-3000)	routes/search.ts:23 (Source Lab)	REMEDIATION_VERIFIED	CVSS:9.8 | Ctrl:95.0	CLOSED_VERIFIED
UFR-043-002	F-02 (ASSET-JS-3000)	routes/login.ts:34 (Source Lab)	REMEDIATION_VERIFIED	CVSS:9.8 | Ctrl:95.0	CLOSED_VERIFIED
UFR-043-003	F-03 (ASSET-JS-3000)	server.ts:412 (Source Lab)	REMEDIATION_VERIFIED	CVSS:8.6 | Ctrl:95.0	CLOSED_VERIFIED
UFR-043-004	F-04 (ASSET-JS-3000)	server.ts:265 (Source Lab)	REMEDIATION_VERIFIED	CVSS:7.5 | Ctrl:0.0	CLOSED_VERIFIED
UFR-043-005	F-05 (ASSET-JS-3000)	server.ts:118 (Source Lab)	REMEDIATION_VERIFIED	CVSS:5.4 | Ctrl:54.0	CLOSED_VERIFIED

10.1 Autonomous 9-Stage Orchestration Architecture & Centralized Version Manifest

Stage	Engine Module (Version)	Execution Outcome
Stage 1-2	Scope & WebPulse 2.6 + TargetIntel 2.6	Verified 1 in-scope asset(s) (127.0.0.1), 1 open TCP ports, and 22 HTTP endpoints.
Stage 3	ENUMCORE 2.6	Mapped CPEs and separated precondition-verified KEVs from banner-only candidates.
Stage 4-5	HeaderPolicyEvaluator 2.6 (Context & CSP Report-Only) & EVE 2.6	Executed verified PoC probes (JS-SQLI-SEARCH-001, JS-AUTH-BYPASS-001, JS-BAC-ADMIN-USERS-001) within RoE.
Stage 6-7	Expedite Strike 2.6 & AttackGraph 2.6 (Causal Edge & Continuous Diff)	Assigned 4-level admin boundary taxonomy and built per-edge evidence-backed attack chains.
Stage 8-9	RiskEngine 2.6, RTEX 2.6 & Noctis 2.6	Computed 7-dimension risk (T0=7.5/10, T1=1.2/10) and signed RFC 8032 Ed25519 manifest.

11. Sign-Off & Deliverables Attestation (TrePath 2.6 Autonomous Attack-Path Validation, Target Intelli

Role	Attestation Statement	Signature / Timestamp
Lead Penetration Tester	All findings, origins, and PoC transcripts verified against EvidenceCore SHA-256 & Ed25519 seals.	SIGNED | 2026-11-02 17:58:04 UTC
Principal Security Architect	TrePath 2.6 Autonomous Attack-Path Validation, Target Intelligence & RTEX Assurance Engine (TP26-BUILD-20261102-AUTONOMOUS-ASSURANCE) AT-01..AT-10, NG-01..NG-06 & 26/26 Quality Gates passed.	VERIFIED | 2026-11-02 17:58:04 UTC
Client System Owner	Acknowledges receipt of prioritized remediation roadmap and RTEX retest workflow.	_____